

CYBERSECURITY

LAB7b: Session Hijacking with Hetty

D.E. MENACER (CEH)

Copyright © ESI – 2026

HIJACK A SESSION USING HETTY

- **Hetty** is an **HTTP toolkit** for security research.
- It aims to become an open-source alternative to commercial software such as Burp Suite Pro, with powerful features tailored to the needs of the InfoSec and bug bounty communities.
- Hetty can be used to perform Machine-in-the-middle (MITM) attack, manually create/edit requests, and replay proxied requests for HTTP clients and further intercept requests and responses for manual review.

HIJACK A SESSION USING HETTY

- Here, we will use the Hetty tool to intercept HTTP traffic on the target system.
- We will use **Windows 11** machine as an attacker machine and **Windows Server 2022** machine as a target machine.

LAB: HETTY

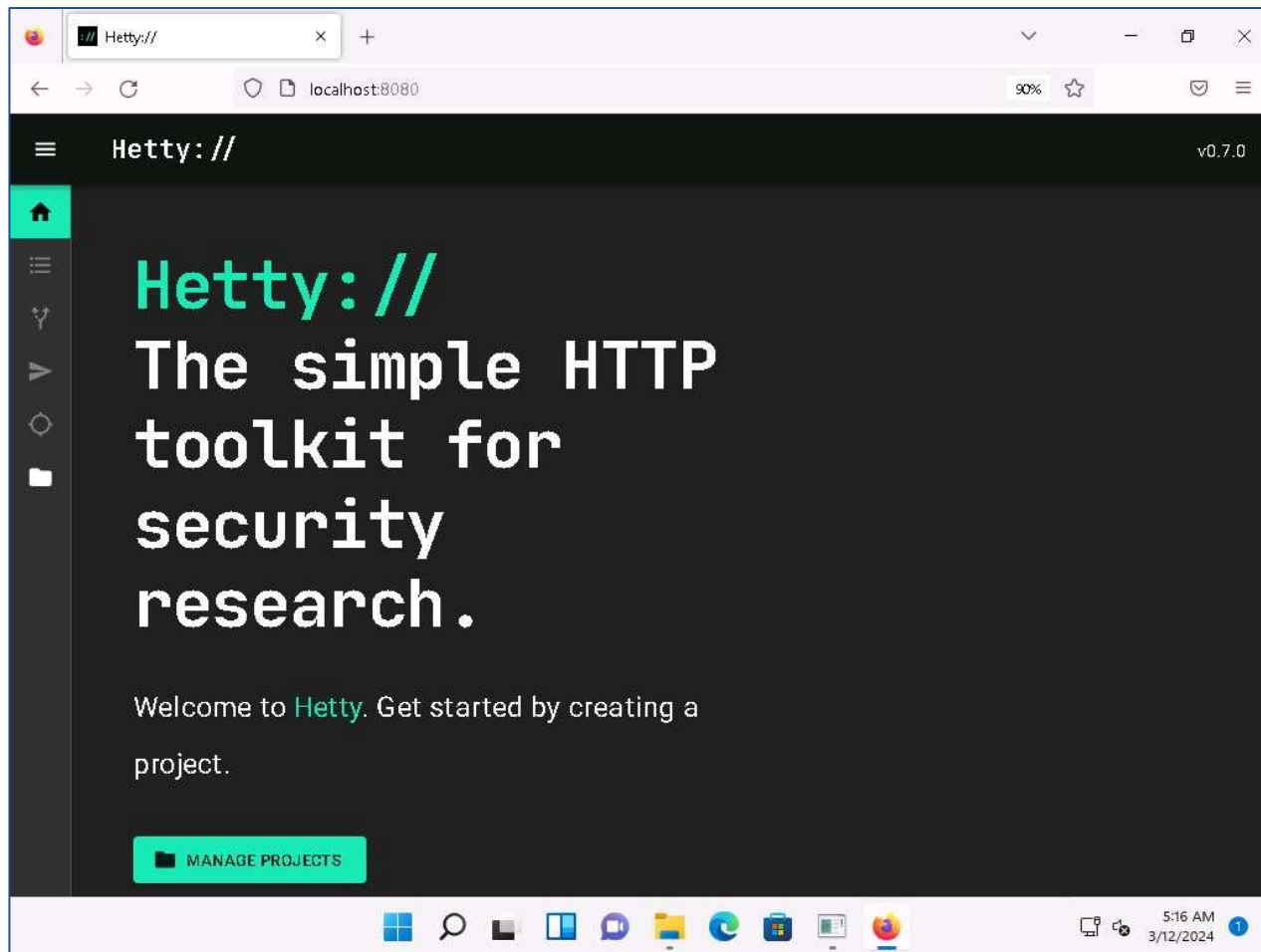
- Click **Windows 11** to switch to the Windows 11 machine.
- Navigate to \Hetty and double-click **hetty.exe**.
 - If an Open File - Security Warning window appears, click Run.
- A Command Prompt window appears, and Hetty initializes.

```
2024/03/12 05:14:27 +[34mINFO+[0m +[36m[main]+[0m Hetty (v0.7.0) is running on :8080 ...  
2024/03/12 05:14:27 +[34mINFO+[0m +[36m[main]+[0m +[32mGet started at http://localhost:8080+[0m
```

OPENING HETTY

- Now, minimize all the windows and launch any web browser (here, Mozilla Firefox).
- Go to <http://localhost:8080> to open Hetty dashboard.
- In the Hetty dashboard, click **MANAGE PROJECTS** button.

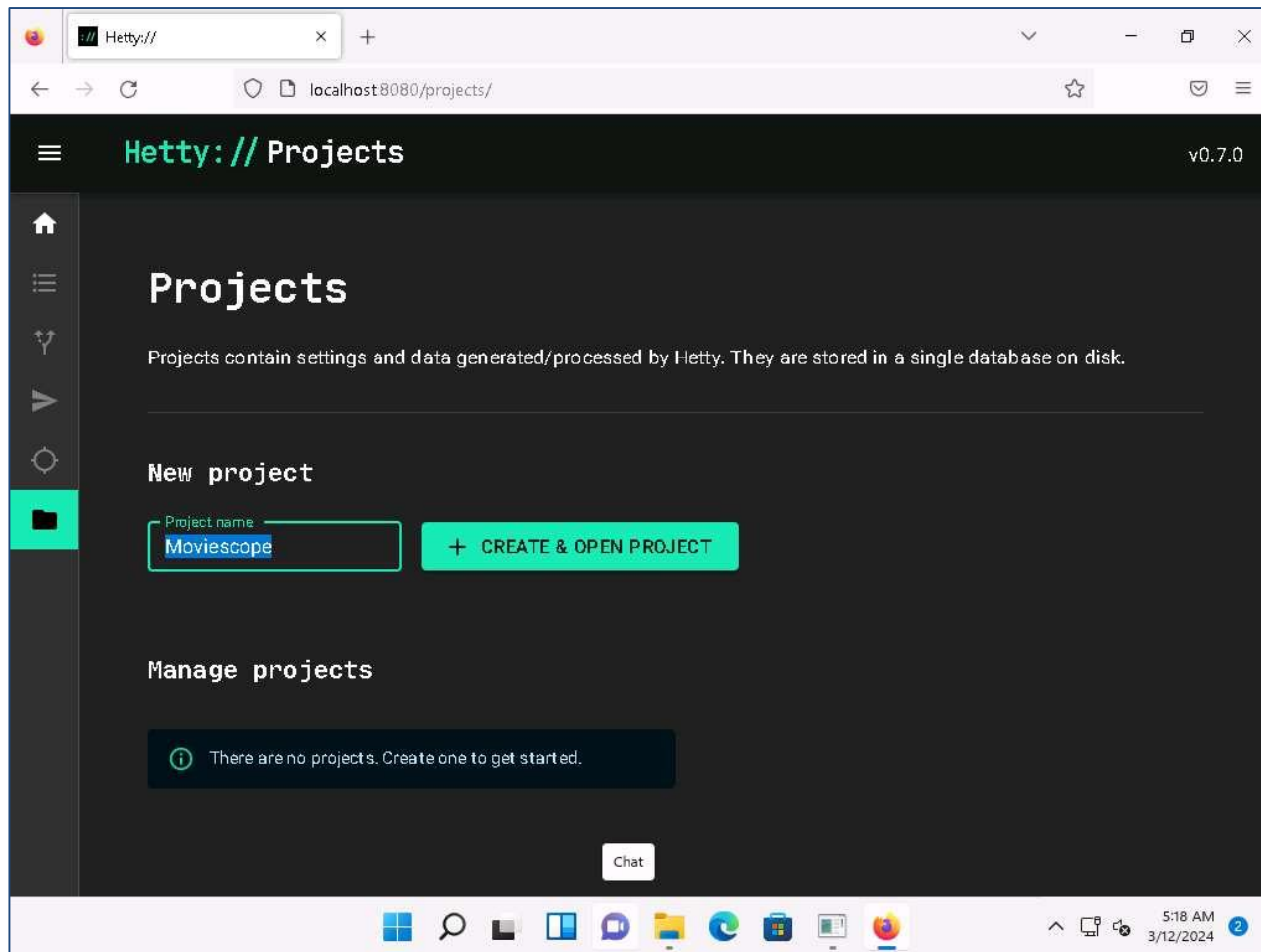
FIRST WINDOW



HETTY PROJECT

- **Projects** page appears, type **Project name** as **Moviescope** and click + **CREATE & OPEN PROJECT** button.
- You can observe that a new project name **Moviescope** has been created under **Manage projects** section with a status as **Active**.

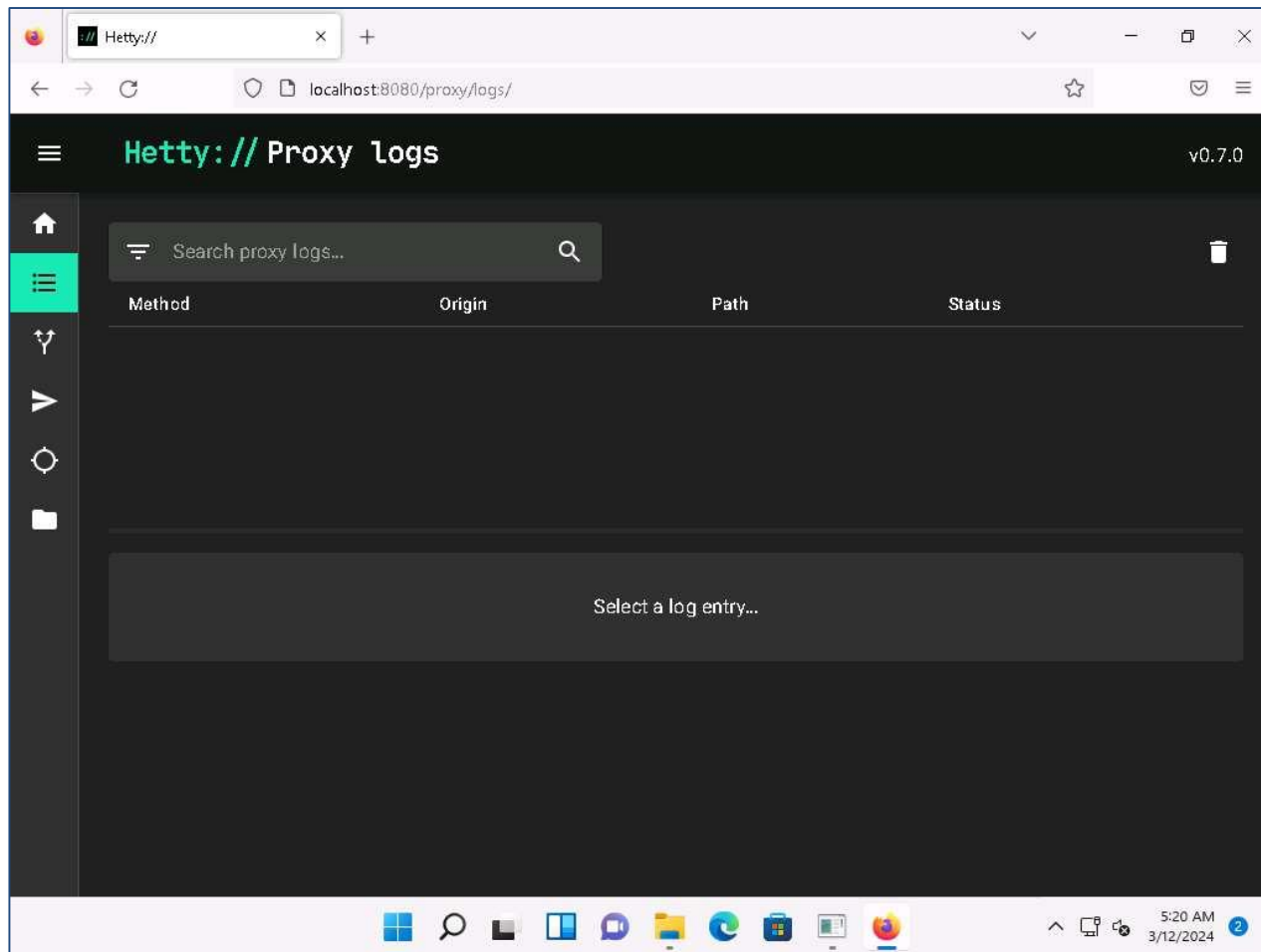
MOVIESCOPE PROJECT



PROXY LOGS

- Click Proxy logs icon () from the left-pane.
- A Proxy logs page appears, as shown in the screenshot.

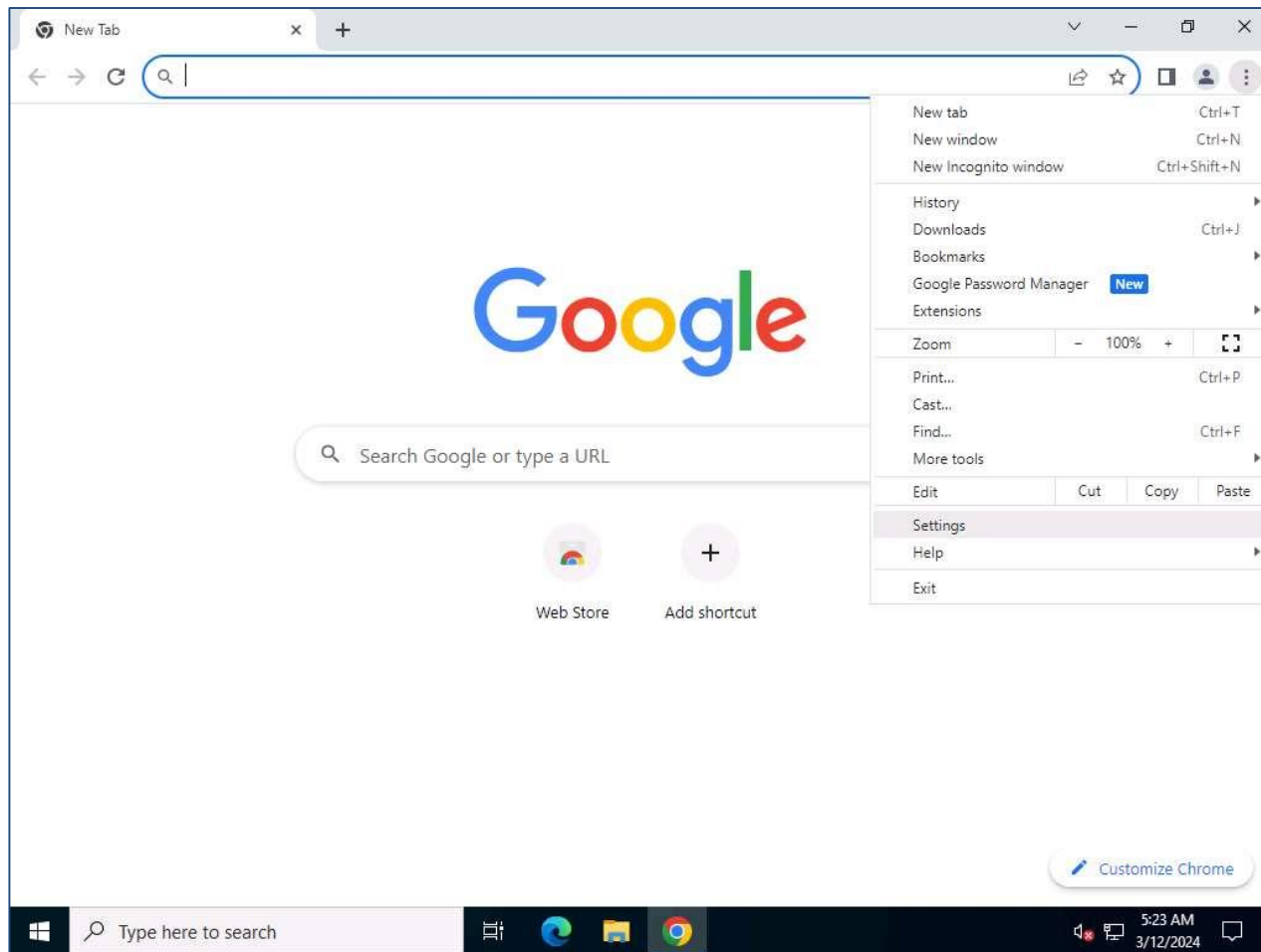
PROXY LOGS



BROWSER SETTINGS

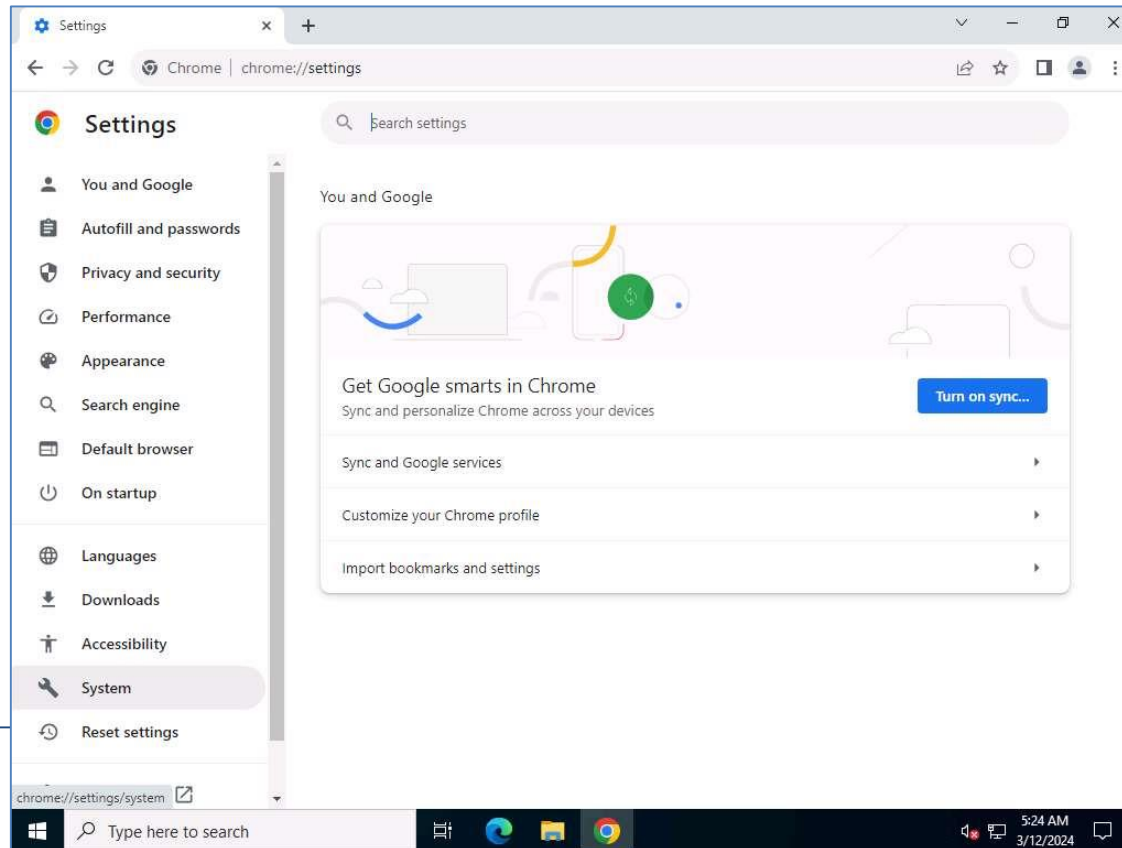
- Now, click Windows Server 2022 to switch to the **Windows Server 2022** machine.
- Click Ctrl+Alt+Delete to activate the machine and login using **Administrator/Pa\$\$w0rd**.
- Open **Google Chrome** web browser, click the **Customize and control Google Chrome** icon, and select **Settings** from the context menu.

BROWSER SETTINGS



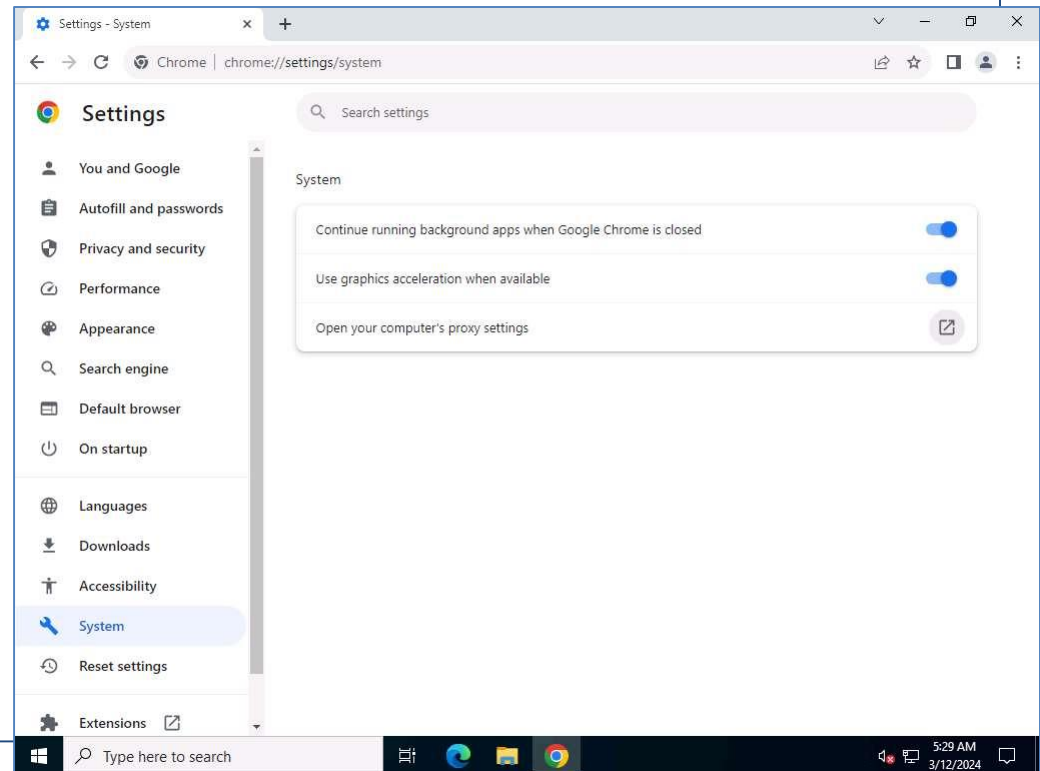
BROWSER SETTINGS

- On the Settings page, scroll-down and click System in the left-pane.



BROWSER PROXY SETTINGS

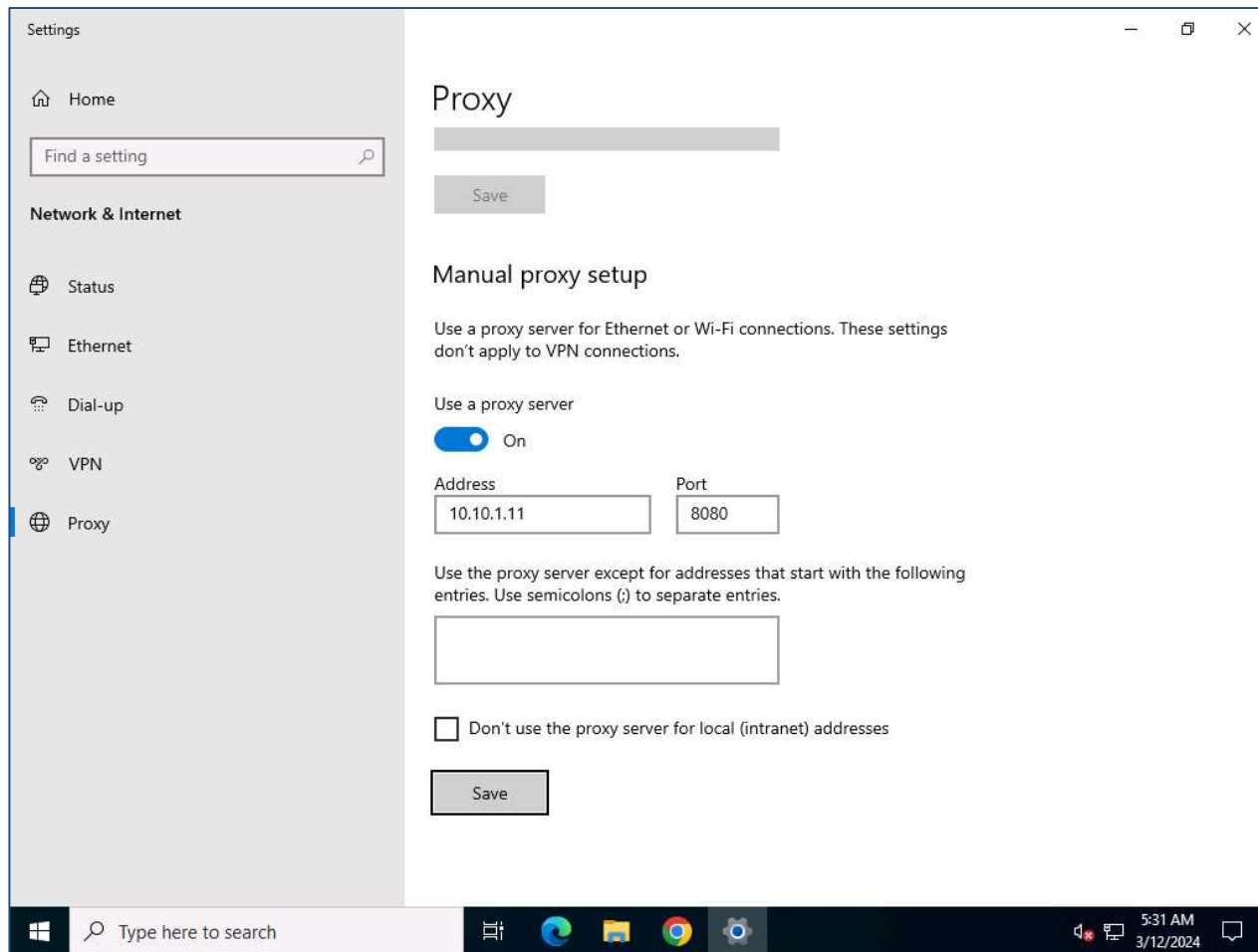
- Scroll-down to the System section and click Open your computer's proxy settings to configure a proxy.



BROWSER PROXY SETTINGS

- A **Settings** window appears, with the Proxy settings in the right pane.
- In the **Manual proxy setup** section, make the following changes:
 - Under the Use a **proxy server option**, click the **Off** button to switch it **On**.
 - In the Address field, type **10.10.1.11** (the IP address of the attacker's machine, here, Windows 11).
 - In the Port field, type **8080**.
- Click **Save**.

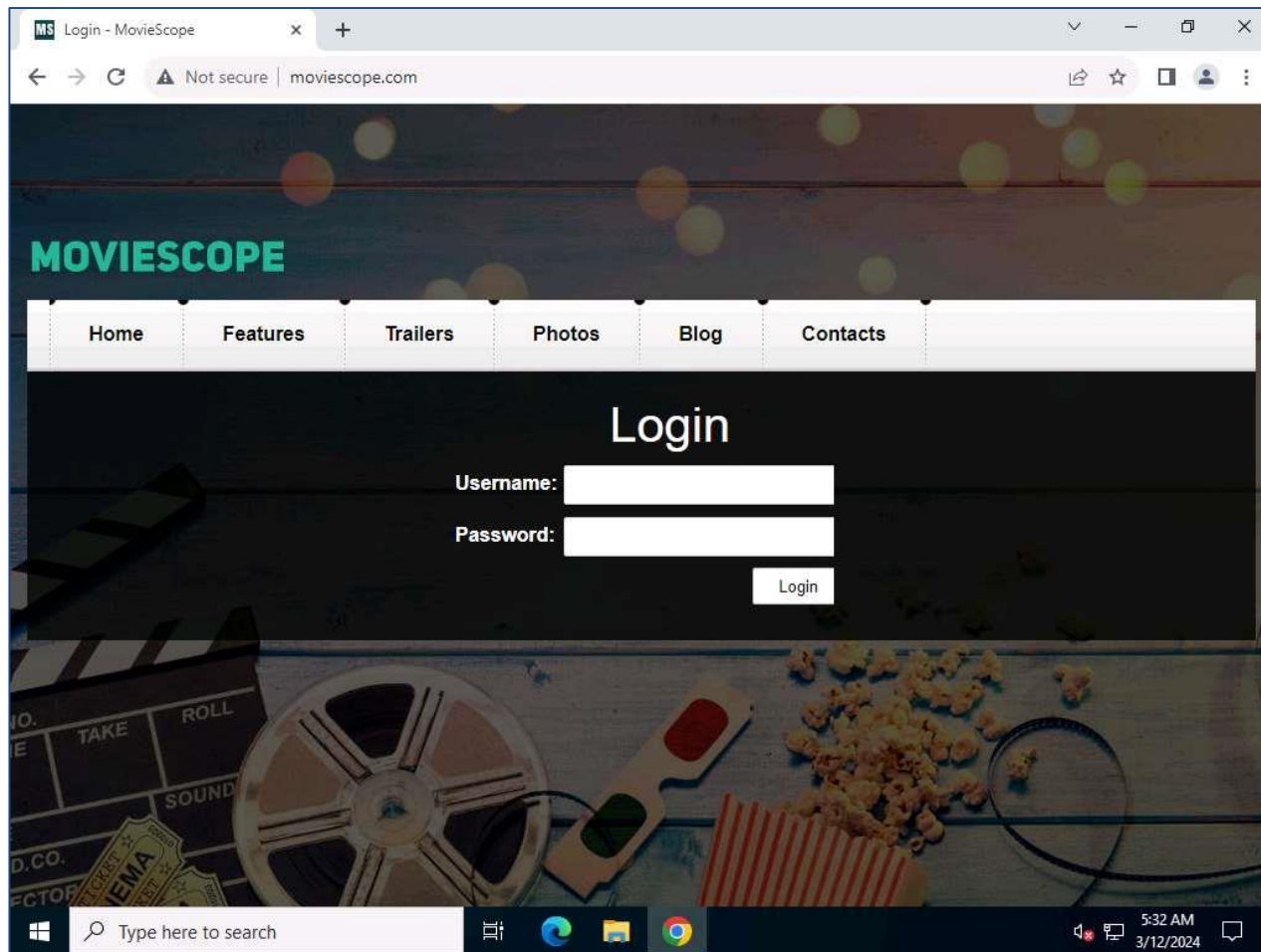
BROWSER PROXY SETTINGS



ENDING PROXY SETTINGS

- After saving, close the **Settings** and browser windows.
- You have now configured the **proxy settings of the victim's machine**.
- Now, in the web browser go to <http://www.moviescope.com>

OPENING MOVIESCOPE WEBSITE



CAPTURED LOGS

- Click **Windows 11** to switch to the Windows 11 machine.
- You can observe that **the logs are captured in the Proxy logs page**.
- Here, we are focusing on logs associated with **moviescope.com** website.

CAPTURED LOGS

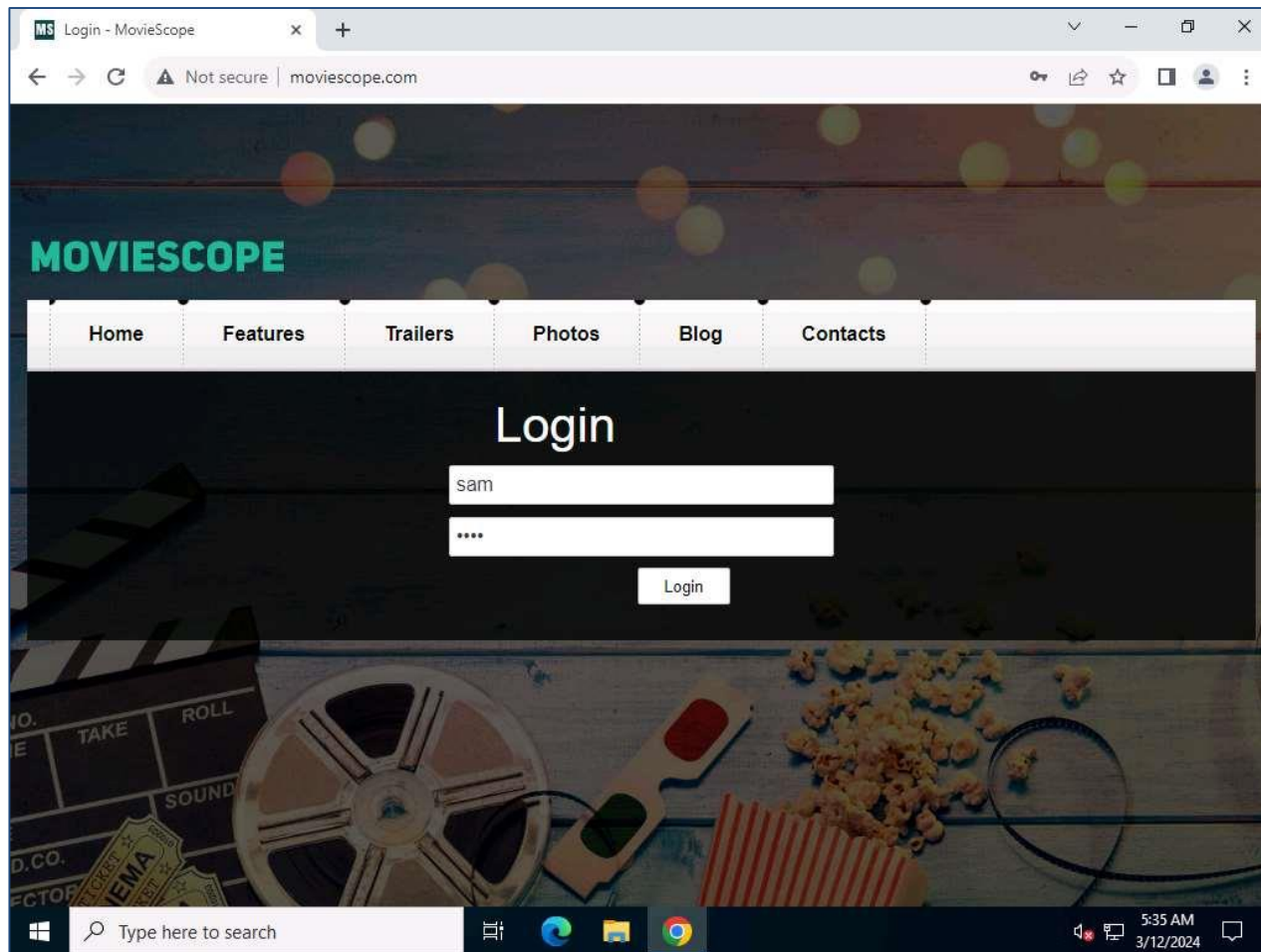
The screenshot displays the Hetty:// Proxy logs interface in a web browser. The browser's address bar shows the URL `localhost:8080/proxy/logs/`. The interface has a dark theme with a sidebar on the left containing navigation icons. The main content area is titled "Hetty:// Proxy logs" and includes a search bar labeled "Search proxy logs...". Below the search bar is a table of captured logs with the following columns: Method, Origin, Path, and Status. The table contains eight entries, all with a Method of "GET". The Status column uses colored circles to indicate success (green) or failure (orange). A trash icon is located in the top right corner of the log list. Below the table is a large grey box with the text "Select a log entry...". The Windows taskbar at the bottom shows the time as 5:34 AM on 3/12/2024.

Method	Origin	Path	Status
GET	http://www.moviescope...	/js/script.js	200 OK
GET	http://www.moviescope...	/css/common.css	200 OK
GET	http://www.moviescope...	/css/style.css	200 OK
GET	http://fonts.googleapis....	/css?family=PT+Sans	404 Not Found
GET	http://www.moviescope...	/css/grid.css	200 OK
GET	http://www.moviescope...	/	200 OK
GET	http://ipv6.msftconnect...	/connecttest.txt	200 OK
GET	http://www.msftconnec...	/connecttest.txt	200 OK

LOGGING AS A VICTIM

- Click **Windows Server 2022** to switch back to the Windows Server 2022 machine.
- In the **MovieScope website**, login as a victim with credentials as **sam/test**.

LOGGING AS A VICTIM



CHECKING LOGS

- Now, click **Windows 11** to switch to the Windows 11 machine.
- In the **Proxy logs page**, scroll-down to check more **logs** on **moviescope website**.
- Check for **POST** log captured for the target website.

CHECKING LOGS

The screenshot displays the Hetty:// Proxy Logs application interface. The browser address bar shows the URL `localhost:8080/proxy/logs/?id=01HRSASFV2C7KKQ0CSEG4HMEQ`. The application title is "Hetty:// Proxy logs" with version "v0.7.0".

A search bar labeled "Search proxy logs..." is at the top. Below it is a table of intercepted requests:

Method	Origin	Path	Status
GET	http://www.moviescope...	/images/content/main_slider_01.jpg	200 OK
GET	http://www.moviescope...	/index.aspx	200 OK
POST	http://www.moviescope...	/	302 Found
GET	http://armmf.adobe.com	/arm-manifests/win/ServicesUpdater/DC/AcroManifest...	200 OK
GET	http://ocsp.digicert.com	/MFEwTzBNMEswSTAJBgUrDgMCGGUABBSRXerF0eFe...	200 OK

The selected request is a POST to `/` with status `302 Found`. The details panel shows the request body (324 bytes) and the response body (128 bytes). The response body contains HTML code indicating a redirect:

```
<html><head><title>Object moved</title></head><body><h2>Object moved to <a href="/index.aspx">here</a>.</h2></body></html>
```

The Windows taskbar at the bottom shows the time as 5:38 AM on 3/12/2024.

CAPTURED USER CREDENTIALS

- Select the **POST** request and in the lower section of the page, select **Body** tab under POST section.
- Under the Body tab, you can observe the **captured user credentials**, as shown in the screenshot.
- The **captured credentials** can be used to **log in to the target user's account and obtain further sensitive information**.

CAPTURED USER CREDENTIALS

The screenshot displays the Hetty:// Proxy logs interface in a web browser. The address bar shows the URL `localhost:8080/proxy/logs/?id=01HRSASFV2C7KKQ0CSEG4HMEQ`. The interface title is **Hetty:// Proxy logs** with version **v0.7.0**. A search bar labeled "Search proxy logs..." is at the top. Below it, a table lists proxy logs:

Method	Origin	Path	Status
GET	http://www.moviescope...	<code>/index.aspx</code>	200 OK
POST	http://www.moviescope...	<code>/</code>	302 Found
GET	http://armmf.adobe.com	<code>/arm-manifests/win/ServicesUpdater/DC/AcroManifest...</code>	200 OK

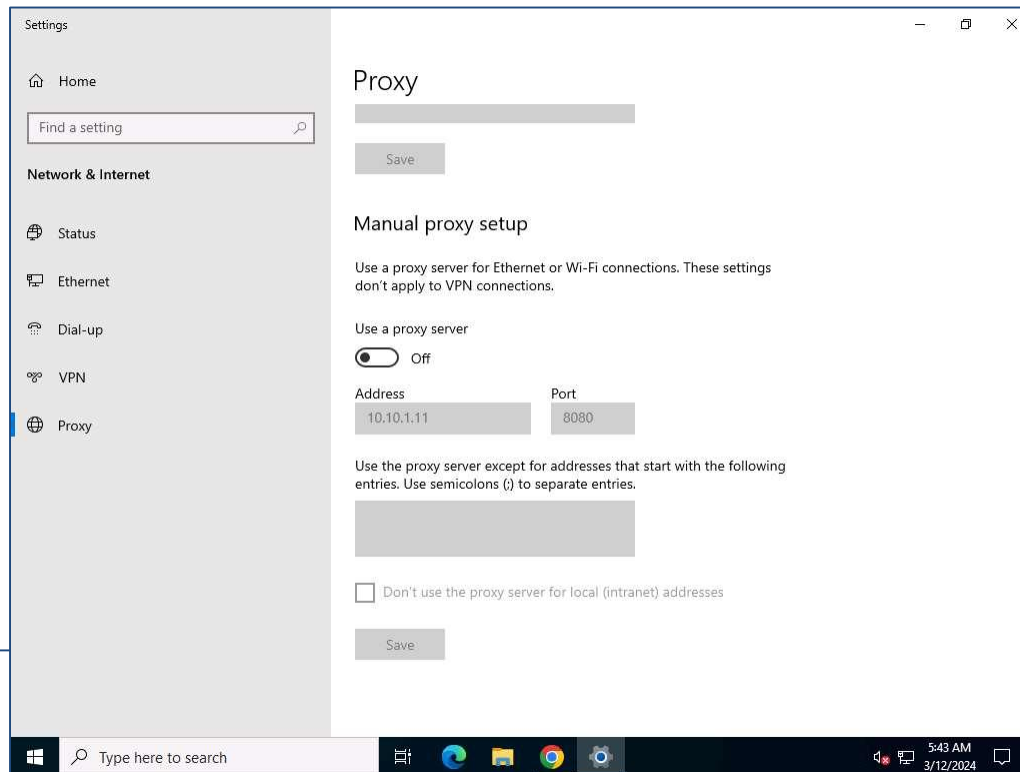
The **POST /** log entry is selected. The **Body (324 bytes)** tab is active, showing the request body. A red box highlights the credentials: `txtusername=sam&txtpwd=test&btnlogin=Login`. The **Body (120 bytes)** tab shows the response body, which is an HTML page titled "Object moved" with a redirect to `/index.aspx`.

ENDING THE LAB

- Now, we shall change the proxy settings back to the default settings.
- To do so, click Windows Server 2022 to switch back to the Windows Server 2022 machine and perform Steps 13-15 again.

ENDING THE LAB

- In the **Settings** window, under the **Manual proxy setup** section in the right pane, click the **On** button to toggle it back to **Off**, as shown in the screenshot.



ENDING THE LAB

- This concludes the demonstration of HTTP traffic interception using **Hetty**.
- Close all open windows and document all the acquired information.

Question: Q1

- Use the **Hetty** tool to intercept HTTP traffic on the Windows Server 2022 machine.
- Enter the URL that was entered in the address bar of the browser to open **Hetty** dashboard.
 - ANSWER =

Question: Q2

- Use the **Hetty** tool to intercept HTTP traffic on the Windows Server 2022 machine.
- What was the password that was captured in **Hetty** tool by intercepting traffic of Windows Server 2022?
 - ANSWER =